Aspectos sociales de ciberseguridad

Unidad 1. Introducción al comportamiento humano en ciberseguridad



Licenciatura en Ingeniería de Ciberseguridad e Infraestructura de Cómputo

M.R.T. Martha Elizabet Domínguez Bárcenas

Universidad Veracruzana

Actividad

Universidad Veracruzana

- Menciona al menos 5 buenas prácticas de ciberseguridad que conozcas

- ¿Conoces alguna buena práctica de seguridad con la que no cumplas?

- Reflexiona y comparte, ¿qué es lo que te motiva a evitar el cumplimiento de una buena práctica de seguridad conocida?

SECC 3

BUENAS PRÁCTICAS	PRÁCTICAS NO CUMPLIDAS	RAZÓN PARA NO CUMPLIR
- Diferentes contraseñas - MFA - Nombres de usuario no reveladores - Gestor de contraseñas - Actualización de dispositivos - No abrir cualquier enlace - No usar software pirata - Copias de seguridad - No compartir contraseñas - Verificar el origen de los mensajes - No incluir datos personales en contraseñas - Usar VPN en redes públicas - Limitar información que se comparte en redes sociales - Desactivar wifi y bluetooth cuando no se utiliza - Usar antivirus	- Respaldar datos - Repetición de contraseñas - Uso de antivirus - Actualización de sistemas - Uso de software pirata - Desactivar wifi y bluetooth - No usar caracteres especiales en contraseñar - Cambio periodico de contraseñas - Compartir contraseñas - Nombre de usuario revelador - No usar gestor de contraseñas - Tener desactivado el cifrados del disco	- No guardo nada importanta - Muchas cuentas diferentes, costumbre, pereza - Remuneración económica - Olvido - Facilidad al recordar - Pereza, costumbre - Beneficio personal - Falta de tiempo - Mantener el control, miedo a perder la contraseña maestra - No se, por necesidad (otro SO alternativo)

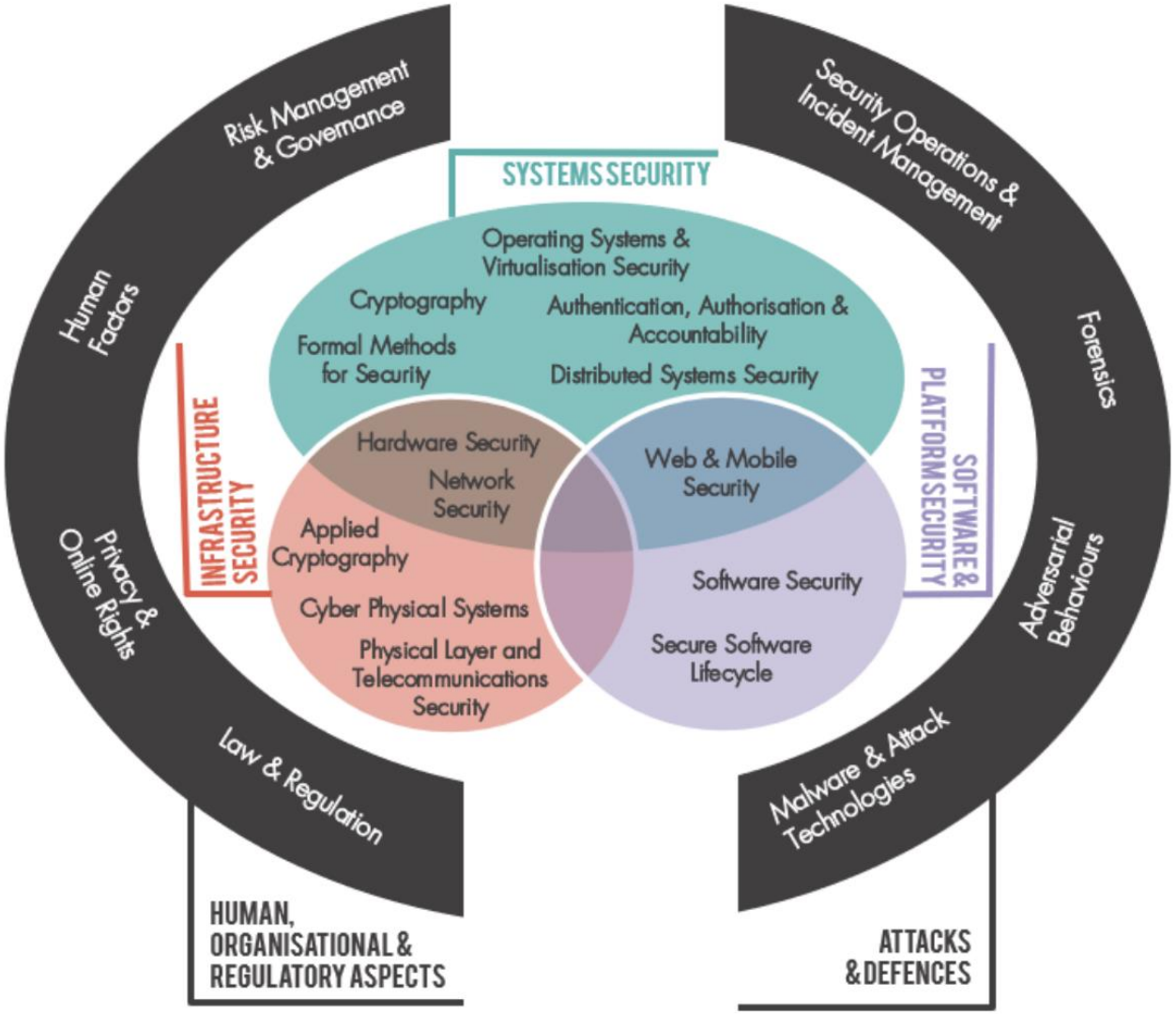
SECC 1

BUENAS PRÁCTICAS	PRÁCTICAS NO CUMPLIDAS	RAZÓN PARA NO CUMPLIR
- NO ABRIR LINKS DESCONOCIDOS - NO USAR REDES PÚBLICAS - MFA (AUTENCICACIÓN MULTIFACTOS - VERIFICAR SEGURIDAD DE LOS SITIOS WEB - REALIZAR COPIAS DE SEGURIDAD - CAMBIAR REGULARMENTE DE CONTRASEÑA - ACTUALIZACIÓN DE SOFTWARE - CONTRASEÑAS ROBUSTAS - CONTRASEÑAS DIFERENTES - LEER TÉMINOS Y CONDICIONES DE LOS SERVICIOS - USO DE GESTOR DE CONTRASEÑAS - USO DE SOTFWARE LEGAL - USAR VPN EN REDES PÚBLICAS	- NO CAMBIAR CONTRASEÑA REGULARMENTE - NO HACER RESPALDOS - MISMA CONTRASEÑA - COMPARTE ACCESO A DISPOSITIVOS - USO DE SOFTWARE CRACKEADO - LECTURA DE TÉRMINOS Y CONDICIONES - NO USAS VPN - USO DE REDES PÚBLICAS	- DESCUIDO (OLVIDO) - OLVIDO - PROBLEMAS DE MEMORIA - TIEMPO (PRACTICIDAD) - POR FALTA DE RECURSOS - NECESIDAD DE USO DE PRODUCTO O SERVICIO - DESCONOCIMIENTO - AHORRO FINANCIERO

Universidad Veracruzana

Cyber Security Body Of Knowledge (CyBOK)

- El CyBOK tiene por objeto codificar los conocimientos fundamentales y generalmente reconocidos sobre ciberseguridad
- Pretende se una guía sobre el conjunto de conocimientos para desarrollar programas educativos en el área de ciberseguridad
- Conocimiento existente en literatura como libros de texto, artículos de investigación académica, reportes técnicos, white papers y normas
- Define **21 Áreas de Conocimiento** en Ciberseguridad

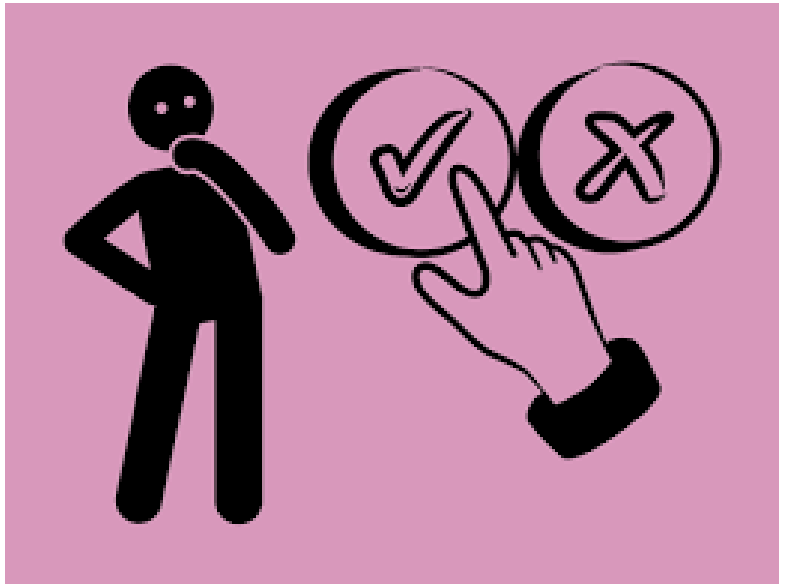


- Acciones de una persona
- Lo que se espera que se haga
- Patrones que sigue una persona, que dictan como reacciona a su ambiente o contexto
- Patrones que sigue una persona y que lo definen

Comportamiento humano

- **Comportamiento**.
  - Manera de comportarse.
  - Sinónimos: conducta, proceder, actuación, pauta, práctica, modales (RAE)
  - Conducta dentro de un espacio y un tiempo determinado (UNIR, s.f.).

- **Conducta**.
  - Respuesta a una motivación (UNIR, s.f.).
  - "Proceso, o conjunto de procesos, que incluye la elaboración o interpretación del estímulo, procesos asociativos que transforman e integran la información recibida con la experiencia y la situación actual del sujeto, y una selección y ejecución de acciones específicas… **Toda conducta se concibe dentro de un contexto, tanto natural como construido**" (Arnal, 2020).



Comportamiento humano



- De acuerdo con Lerner et al.(2024):
  - **Comportamineto humano**. Potencial y capacidad expresada para la actividad física, mental y social durante las fases de la vida humana (Lerner et al., 2024).
  - Influencia de **factores internos**
    - Fases sucesivas de crecimiento
    - Características físicas, fisiológicas y de comportamiento distintas
  - Se considera que el comportamiento mental óptimo se alcanza en la edad adulta temprana.

Contextos de comportamiento humano

“Para comprender porque una persona se comporta de cierta manera, es necesario entender el contexto en el que se encuentra inmersa”

Físico

Estímulos ambientales: anuncios, aparatos de ejercicio, entornos verdes, contaminación, tráfico, etc.

Social

Organización: observación, comportamiento, modelos, roles, normas, valores

Compañeros: personalidad, actitudes, percepción, motivación, comportamiento individual y grupal.

Universidad Veracruzana

Ciberseguridad

- La ciberseguridad se refiere a la **protección de los sistemas** de información (hardware, software e infraestructura asociada), los **datos** que contienen y los **servicios** que prestan, frente al **acceso no autorizado, los daños o el uso indebido**. Esto incluye los daños causados **intencionadamente** por el operador del sistema **o accidentalmente**, como resultado del incumplimiento de los procedimientos de seguridad



Comportamiento humano en seguridad

Principios para el diseño de la seguridad

1883

Principio para operar un **sistema de comunicación seguro,** con enfoque en **factores humanos** (Auguste Kerckhosffs en 1883)

- “debe ser fácil de usar y no debe exigir tensión mental ni el conocimiento de una larga serie de reglas”.



Principios para el **diseño de seguridad** que contemplan el **comportamiento humano** (Saltzer y Schroeder en 1975):

- **Psicología**. Los mecanismos deben ser psicológicamente aceptables para quien tiene que aplicarlos.
- **Factores humanos**. Los individuos y la organización en general deberían lidear con el menor número posible de mecanismos de seguridad distintos.
- **Ciencia y economía del crimen**. El esfuerzo requerido para superar una medida de seguridad debe exceder los recursos y las posibles recompensas para el atacante.

1975

¿Por qué no se adoptan las medidas de seguridad?

Universidad Veracruzana

Humanos tratados como componentes	Profesional de la seguridad:	Disyuntiva del usuario:	Respuesta a la situación:
• Control del comportamiento a través de políticas y mecanismos de seguridad.	• Usuarios no entienden los riesgos • Usuarios perezosos	• ¿Hacer lo correcto en materia de seguridad o reducir la productividad?	• Concienciación y educación en materia de seguridad (**Adaptar al ser humano a la tarea**)

Universidad Veracruzana

Adaptar al ser humano a la tarea

Adaptar la tarea al ser humano

Usabilidad

Universidad Veracruzana

Eficacia, eficiencia y satisfacción con la que usuarios específicos logran objetivos específicos en entornos particulares

(ISO 9241-11:2018).

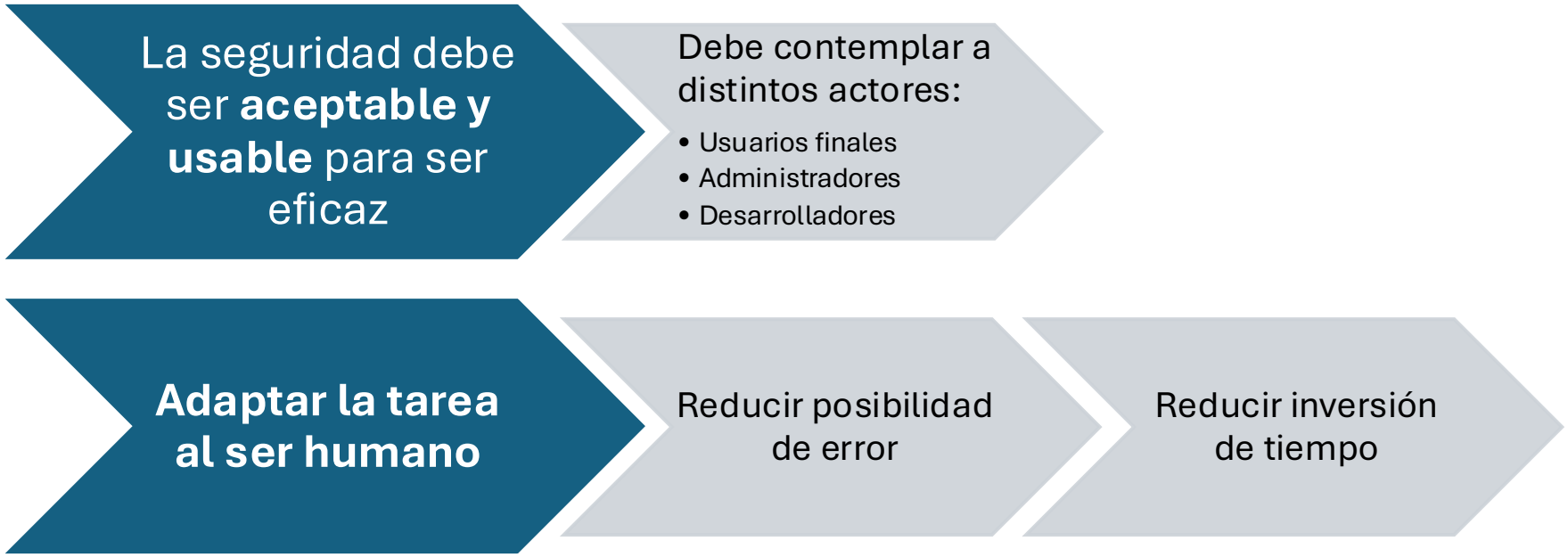
- **Eficacia**: la exactitud e integridad con la que los usuarios especificados pueden alcanzar objetivos especificados en entornos particulares.
- **Eficiencia**: los recursos empleados en relación con la precisión e integridad de los objetivos alcanzados.
- **Satisfacción**: comodidad y aceptabilidad del sistema de trabajo para sus usuarios y otras personas afectadas por su uso.

Seguridad Usable

Universidad Veracruzana

- “La forma de crear una seguridad que funcione es crear seguridad que funcione para las personas” (UK’s National Cyber Security Centre (NCSC)

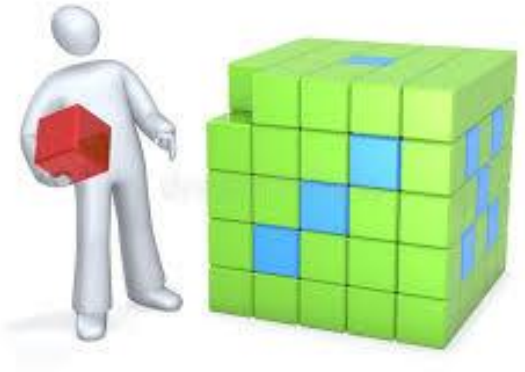
- De acuerdo con Di Nocera et al. (2023)
  - Se refiere al **diseño e implementación de medidas de seguridad considerando las necesidades, habilidades y comportamientos del usuario**.
  - Su objetivo es hacer las **medidas de seguridad más efectivas, minimizando los errores** del usuario e **incrementando el cumplimiento** de los protocolos de seguridad



¿Cómo adaptar la tarea al ser humano?

Universidad Veracruzana

- Capacidades y limitaciones del usuario objetivo.
- Los objetivos que tienen esos usuarios y las tareas que llevan a cabo para alcanzarlos.
- El contexto físico y social de uso.
- Las capacidades y limitaciones del dispositivo en el que se utiliza el mecanismo de seguridad.



Capacidades y limitaciones humanas generales (1)

- Asignar a las personas tareas que exedan sus capacidades significa condenarlas al fracaso.
- Capacidades y limitaciones mentales y físicas
- Los seres humanos pueden centrar su atención principalmente en una tarea a la vez.
- Muchos mecanismos de seguridad exigen más tiempo y atención de la que los humanos pueden dedicar
    - El cerebro deja de prestar atención a las señales que ha clasificado como irrelevantes (**Fatiga por alarma)**



Capacidades y limitaciones humanas generales (2)



- Capacidad mental: Memoria
  - Memoria de corto plazo (STM)
    - Ejemplo: uso de contraseñas de un solo uso (OTP)
  - Memoria de largo plazo (LTM)
    - Los elementos recuperados con más **frecuencia** “vienen a la mente” más rápido.
    - Los elementos almacenados se mantienen por más tiempo, si estos son guardados junto con **imágenes y emociones** asociadas con estos.

Capacidades y limitaciones humanas generales (3)

- Capacidad mental: **Memoria**
  - El problema de las contraseñas
    - Multitud de credenciales
    - Reglas exigidas por los sitios para la creación de contraseñas
    - Contraseñas antiguas guardades en memoria de largo plazo (compiten con las nuevas)

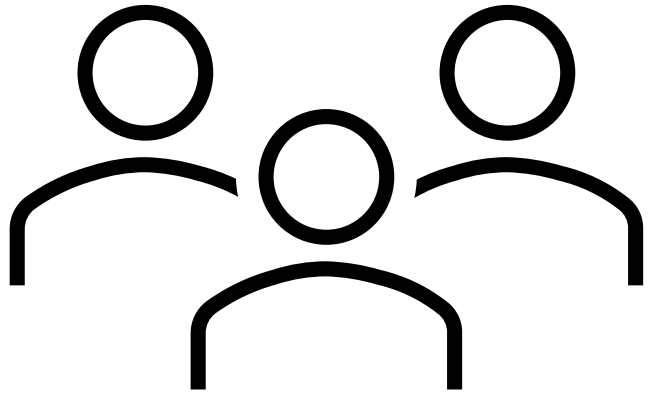
  - Consecuencia
    - Selección de credenciales sesgada hacia las conocidas o las más facilmente distinguibles.
    - Aumenta la probabilidad de que un atacante adivine una contraseña
    - Aumento de restricciones al crear contraseñas
    - Incremento de la carga de trabajo asociada a la tarea de creación de contraseñas





Capacidades y limitaciones humanas generales (3)

- Usuarios con **necesidades adicionales**
  - Niños, Adultos mayores, Personas con alguna discapacidad
  - Condiciones físicas y mentales
    - Falta de extremidades
    - Problemas visuales o auditivos
    - Daltonismo
    - Autismo
    - Epilepsia
  - Valores y normas culturales (genero, edad, cultura nacional, falsas percepciones, reglas poco claras, inexperiencia)
  - Caso: CAPTCHA (basados en texto distorsionado, selección de imágenes, rompecabezas deslizantes, operaciones matemáticas, pruebas de audio, los sistemas invisibles y los basados en comportamiento)



Actividad

- Elige un sector de la población y elabora una tabla donde listes las capacidades y/o limitaciones que podrían influir en la adopción de mecanismos de seguridad:

Población	Capacidad / Limitación	Mecanismo de ciberseguridad	¿Cómo puede influir?

Objetivos y tareas (1)

- Las personas realizan tareas para alcanzar objetivos
- Dos tipos de tareas
  - Tareas **primarias o de producción**
    - Para producir los bienes o servicios de la organización
  - Tareas **habilitadoras**
    - No contribuyen directamente a los procesos empresariales, pero se diseñan **para proteger la capacidad de seguir funcionando a largo plazo**
    - Ejemplo: seguridad, sostenibilidad, formación en materia de diversidad, entre otras.
- Tarea frecuente
  - **Automática**. Requiere automatización para reducir el esfuerzo físico
- Tarea poco frecuente
  - **Consciente**. Requiere reducir el esfuerzo mental



Objetivos y tareas (2)

- Ejemplo:

  Una empleada tiene que autenticarse con una contraseña en una base de datos para averiguar la tarifa por hora que cobra la empresa por los servicios de un especialista concreto. Si lo hace con frecuencia y recuerda la contraseña, solo tardará unos segundos en recordarla e introducirla.

  Pero si acaba de regresar de vacaciones, no la recuerda y tarda 20 minutos en ponerse en contacto con el servicio de asistencia para restablecerla, y luego tiene que pensar y memorizar una nueva contraseña, todo ello antes de poder acceder a la base de datos, la tarea de seguridad se ha convertido de repente en una interrupción enorme y, tal vez, la finalización efectiva de la tarea de producción se vea ahora amenazada.



Objetivos y tareas (3)

- En el ejemplo anterior:
  - ¿Cuál es el objetivo?
  - ¿Cuáles son las tareas primarias?
  - ¿Cuáles son las tareas habilitadoras?



Objetivos y tareas (4)

- **Fatiga de seguridad**
  - Ocurre cuando las tareas para garantizar la seguridad superan el tiempo que el usuario está dispuesto a dedicarles

- Soluciones alternativas a las tareas de ciberseguridad para finalizar la tarea de producción
  - Anotar las contraseñas o compartirlas
  - Guardar copias en texto claro, de documentos que deberían estar cifrados
  - Instalar software que mueva el mouse para que la pantalla no se bloquee



Objetivos y tareas (5)

- Recomendaciones
  - Para diseñar una tarea de seguridad es necesario conocer las tareas de producción y tener en cuenta la carga de trabajo mental y física
  - Antes de seleccionar una medida de seguridad se debe llevar a cabo una auditoría de la carga de trabajo
    - Tiempo para completar la tarea de seguridad
    - Interrupciones que puede causar a la tarea primaria
    - Tiempo y presupuesto disponibles para las tareas habilitadoras
    - Tiempo y presupuesto disponibles para las tareas de seguridad



Objetivos y tareas (6)

- Ejemplos:

  - **Operación normal**: Dentro de la red coorporativa, el usuario se autentica una sola vez y puede acceder al correo, bases de datos y otras herramientas sin autenticación adicional.

  - **Intervención puntual**: si el mismo usuario se conecta desde una red pública o intenta descargar un volumen inusual de información, el sistema le solicita verificación rápida, por medio de autenticación multifactor.

Interacción con el contexto (1)

Universidad Veracruzana

- Características del **contexto físico** que afectan la usabilidad de los mecanismos de seguridad:
  - Luz.
    - Reflejo en pantalla, brillo en cámaras que captan imágenes (rostro, iris)
  - Ruido
    - Interferencia con reconocimiento de voz
    - Aumento de estrés en el usuario y probabilidad de cometer errores
  - Temperatura ambiente
    - Mal funcionamiento de sensores (frío)
    - Lentitud de movimientos en los humanos (frío)
    - Múltiples prendas que impiden movimientos correctos (frío)
    - Incomodidad y sudor (calor)
    - Obstrucción de sensores (calor)
  - Contaminación
    - Obstrucción de sensores
    - Revelación de patrones en pantallas táctiles.



Interacción con el contexto (2)

- Características del **contexto social** que afectan la usabilidad de los mecanismos de seguridad:
  - Influencia en el comportamiento
    - Valores (creencias compartidas sobre lo que es importante y valioso)
    - Normas (reglas y espectativas sobre el comportamiento)
    - Confianza
  - Ejemplo:
    - Si una organización valora la **satisfacción del cliente** y se pide a los empleados que sean **amables** con los clientes en todo momento, una política de seguridad que exija al personal tratar cualquier **consulta** de un cliente como un posible **intento de obtener información** no será adecuada



Interacción con el contexto (3)

- Reto de los profesionales de la seguridad
  - Identificar todos los factores que pueden afectar a la seguridad y la usabilidad

  - **Indagación o investigación contextual**
    - Acercamiento al usuario
    - Observación de la forma en que realiza las actividades
    - Conversar sobre la actividad que realiza al momento (entrevista)
    - Identificar las tareas que realiza la gente y que la motiva a hacerlo bien.



Capacidades y limitaciones del dispositivo (1)

Universidad Veracruzana

- Las características físicas de un dispositivo pueden dificultar la interacción con los mecanismos de seguridad

- **Ejemplo 1**: Captura de contraseñas complejas en teclados virtuales de un teléfono móvil lleva mucho más tiempo y es más propenso a errores.

- **Implicación**: usuarios optan por contraseñas fáciles de introducir con el mínimo número de pulsaciones



Capacidades y limitaciones del dispositivo (2)

Universidad Veracruzana

- **Ejemplo 2**: Para algunos usuarios, el uso de tokens 2FA resulta difícil y confuso
  - Muy pequeños
  - Implementación distinta de 2FA por cada servicio financiero (banca)
  - Denominación de los diferentes elementos de autenticación (frase de contraseña, código de acceso, frase clave)
- **Recomendación**
  - Tener en cuenta la ergonomía del usuario en las interacciones de seguridad



Digipass

Actividad

- En el contexto de una escuela secundaria mexicana, elige a uno de los actores involucrados e investiga sus características generales, así como las caraterísticas de su contexto (físico y social).

- Sustenta tus conclusiones con fuentes confiables (artículos científicos, artículos de revista, noticias de informantes reconocidos, fuentes académicas, organizaciones reconocidas, etc.)

- Entrega en Eminus

Actividad

- Por equipos, dar lectura a la introducción y la sección asignada del artículo “Usable Security: A Systematic Literature Review”, disponible en https://www.mdpi.com/2078-2489/14/12/641, después comparte lo siguiente:

    1. ¿Cuáles son las estrategias o mecanismos de seguridad usable que se presentan?
    2. ¿Cuáles son las características de los usuarios involucrados?
    3. ¿Cuáles son los parámetros utilizados para medir la usabilidad del mecanismo o estrategia?
    4. ¿Cuáles fueron los resultados en cada caso?
    5. ¿Qué áreas de oportunidad se detectan?

- Entrega en Teams



El error humano

El error humano

- Todos los errores que cometen las personas son predecibles (James Reason, psicólogo).

- Errores como resultado de
  - **Fallos latentes.**
    - Organización y condiciones del lugar de trabajo.
    - Ejemplo: Conflicto entre cumplir con la tarea principal o con la tarea de seguridad

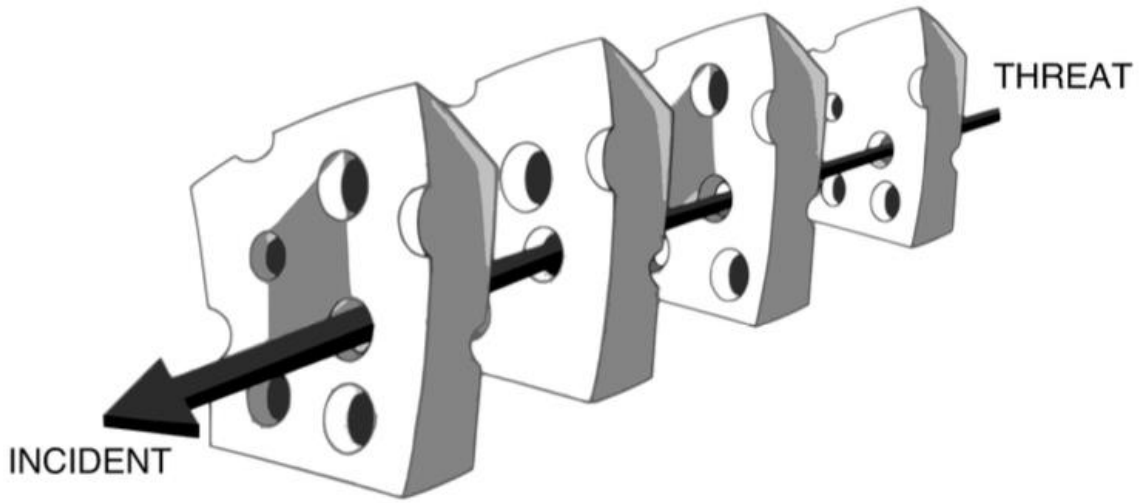
  - **Fallos activos.**
    - Violaciones por parte de los seres humanos.
    - Ejemplo: Empleados que no siguen los procedimientos de seguridad



Modelo del queso suizo

Universidad Veracruzana

- “Una persona puede ser la que haya pulsado el botón equivocado o haya hecho clic en el enlace y haya provocado el incidente. Sin embargo, este incidente ha estado precedido por varios otros fallos que han llevado a esa persona a una situación en la que lo que parecía ser la decisión correcta resultó ser la equivocada”
- Un **incidente** se produce porque una **amenaza** se abrió paso a través de una serie de **vulnerabilidades** en las defensas de la organización.
- El incumplimiento de la seguridad se ignora hasta que se produce un accidente.
- Necesidad de **notificar en cuanto se detecta una posibilidad de incidente** (**cuasi accidente**).



- Huecos = fallas latentes y activas

- Rebanadas = Defensa (mecanismos y políticas de seguridad)

El error humano (2)

Universidad Veracruzana

- Dós áreas en la **toma de decisiones** (Daniel Kahneman, psicólogo):
  - **Pensamiento rápido**
    - Tareas realizadas con frecuencia (**automatización**)
    - Mayoría de las actividades realizadas (aumento de la productividad)
    - Se requieren herramientas que ayuden al usuario a reducir los riesgos de seguridad (p.e. herramientas para distinguir entre correos auténticos e intentos de phishing).
  - **Pensamiento lento**
    - Tareas realizadas por primera vez o con poca frecuencia (**desarrollo consciente**)
- **Problemas complejos**
  - Combinación de **pensamientos lentos y rápidos**
  - Consideración de expertos en seguridad:
    - “Sin considerar la productividad, **Modo lento = Modo seguro**”
    - Racionalizar o descartar pruebas (detenerse a pensar)
    - Tener en cuenta preocupaciones irrelevantes
    - Gastar tiempo y energía

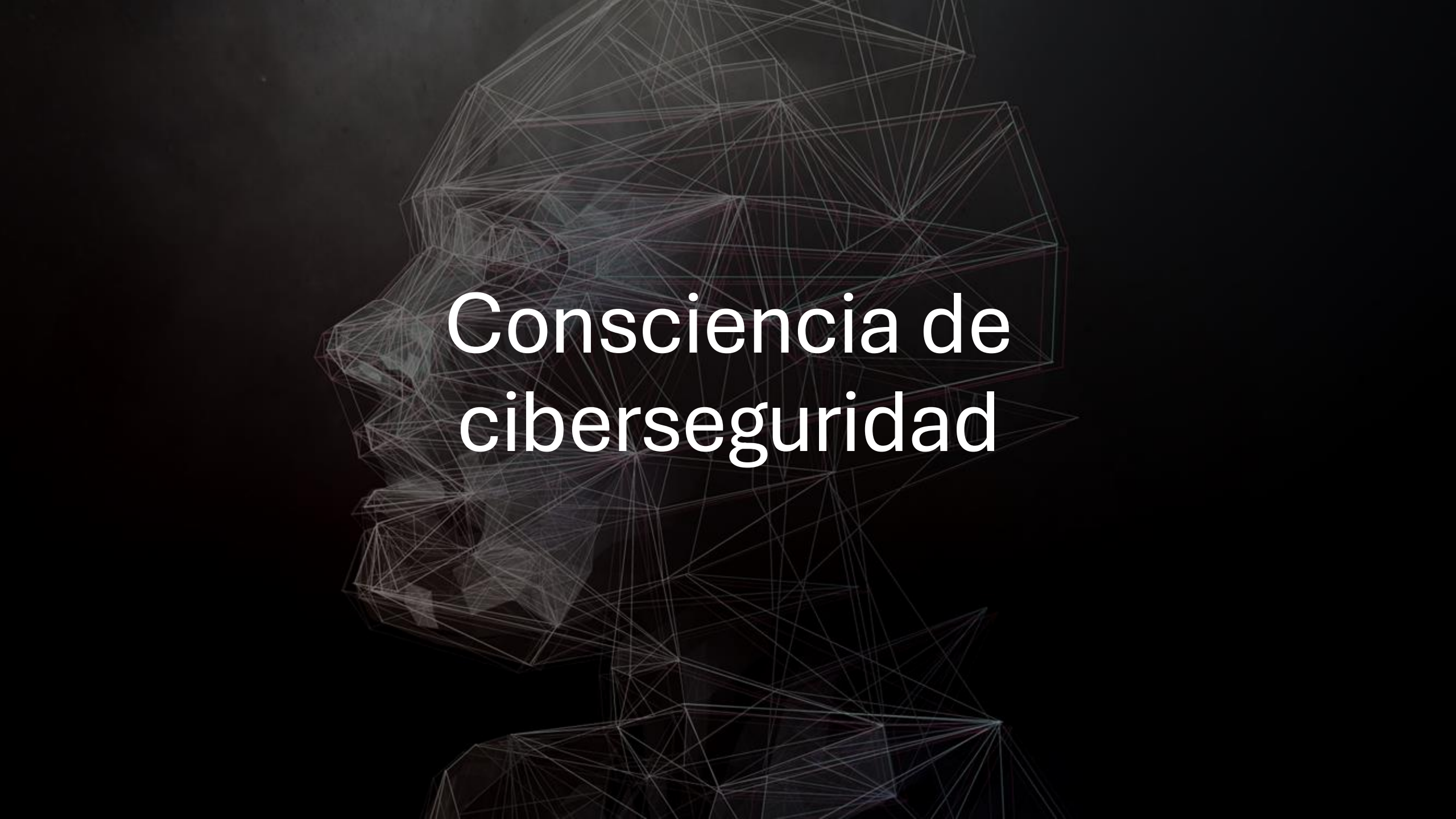
Fallos latentes que pueden generar errores humanos

Universidad Veracruzana

Factores individuales	Factores humanos	Factores relacionados con las tareas **	Factores relacionados con el ambiente de trabajo **
• Fatiga • Inexperiencia • Actitud de riesgo	• Limitaciones de memoria • Hábitos comunes • Supuestos o creencias compartidas: • “la ciberseguridad es responsabilidadel personal técnico” • “no tengo nada de valor”	• Presión del tiempo • Múltiples tareas • Alta carga de trabajo • Monotonía • Aburrimiento • Insertidumbre sobre funciones, responsabilidades y normas	• Interrupción de tareas • Equipos e infomación deficientes • Cambio de normas y procedimientos

** Dependen de la **organización**:

- Revisiones regulares
- Identificar y modificar causas de cuasi accidentes (errores que pudieron ocurrir)
- Tomar en cuenta respuesta en situaciones de estrés (p.e., ataque)


Consciencia de ciberseguridad

Higiene de la seguridad

Universidad Veracruzana

"Nunca emitas una política se seguridad que no se pueda cumplir"

General Douglas MacArthur

Lider militar en la Segunda Guerra Mundial

- Cuando no se siguen las políticas, los profesionales de la seguridad deben investigar el por qué.
- Si el incumplimiento es porque son imposibles o demasiado engorrosas de cumplir, se debe rediseñar la solución.

Higiene de ciberseguridad (Ciberhigiene)

- “Conjunto de **prácticas** de las organizaciones y de las personas, realizadas regularmente para **mantener la salud y seguridad de los usuarios, dispositivos, redes y datos**. Así como para reforzar la **capacidad para recuperarse** en caso de un ataque exitoso”

(Irel, 2023)



- Políticas de seguridad imposibles de cumplir o ineficaces
  - Duda sobre las políticas por parte de los usuarios.
  - Recentimiento y actitud negativa hacia la seguridad y hacia la organización.

Estrategias de atención



- Cuando las personas no siguen las políticas de ciberseguridad
  - **Concienciación**.
    - **Captar la atención** de la gente y **convencerla de la importancia de comprometerse** con la ciberseguridad.
    - Convencer acerca de:
      - Los riesgos son reales y pueden afectar,
      - Hay medidas que se pueden tomar y las personas son capaces de tomarlas.
    - Requiere especialistas en comunicación.
  - **Educación**.
    - Requiere que las personas estén dispuestas a aprender
    - **Informar sobre los riesgos y lo que las personas pueden hacer** para protegerse.
  - **Formación**
    - Apoyar la **adquisición de habilidades a través de la práctica.**
    - **Uso correcto de mecanismos** de seguridad en un entorno de experimentación
    - Como reconocer y responder a un ataque
    - **Reflexión sobre percepciones y sesgos al tomar decisiones** en materia de seguridad.

Cambio de comportamiento

- Saber que hacer y como hacerlo no es suficiente
- Requiere instalarse en la memoria de largo plazo
- Compite con comportamiento ya existente
- La actividad productiva debe continuar mientras se cambia el comportamiento
- Proceso gradual: uno o dos comportamientos a la vez



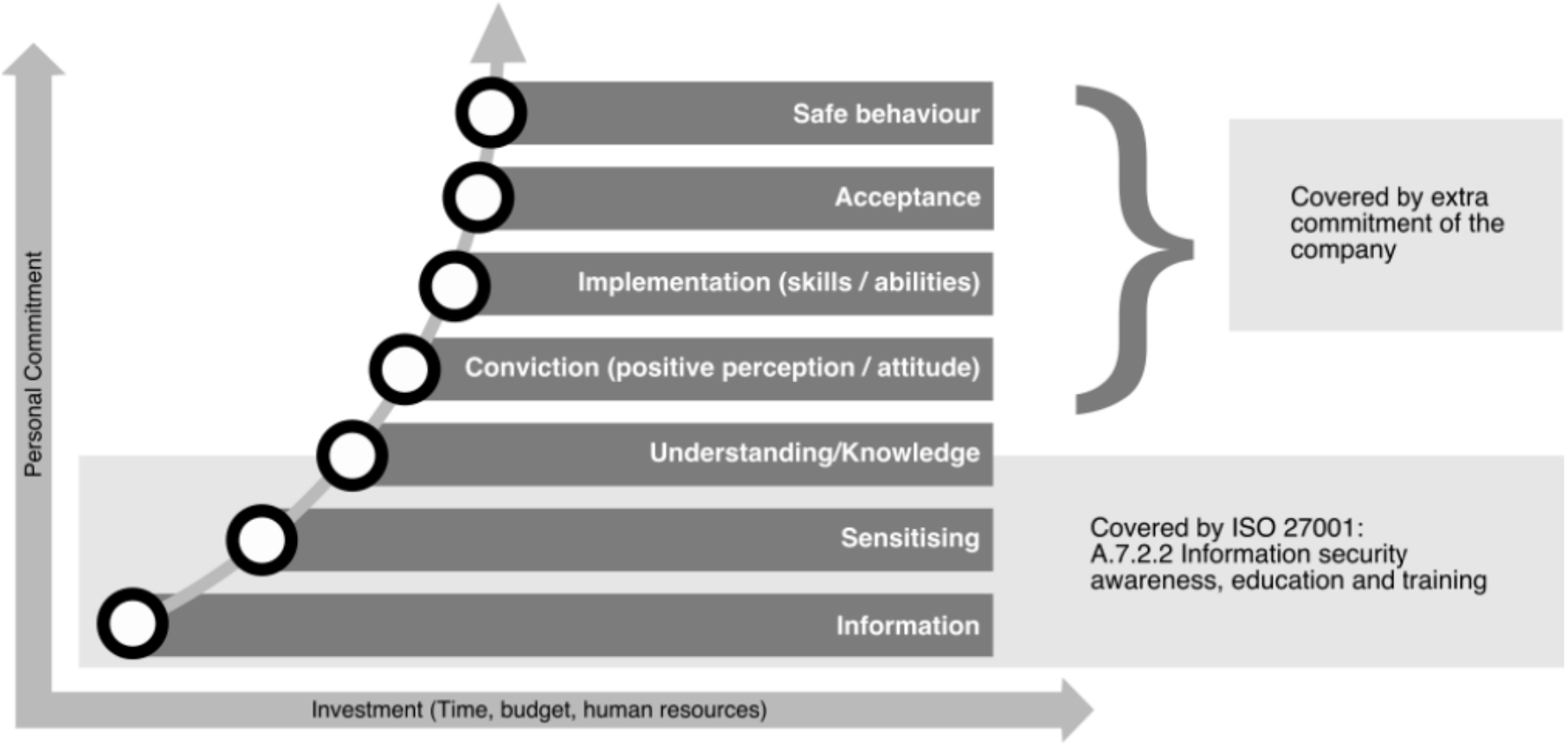
Modelo de cambio de comportamiento de RISCS

Universidad Veracruzana

Confianza en el compromiso del personal (monitoreo constante, detección de puntos débiles, nececidad de cambio)

Asignación de roles (dar identidad a la seguridad)

Cumplimiento en todos los niveles



Behaviour change model from Research Institude in Science of Cybersecurity (RISCS) of UK (2015)

Modelo de Comportamiento de Fogg

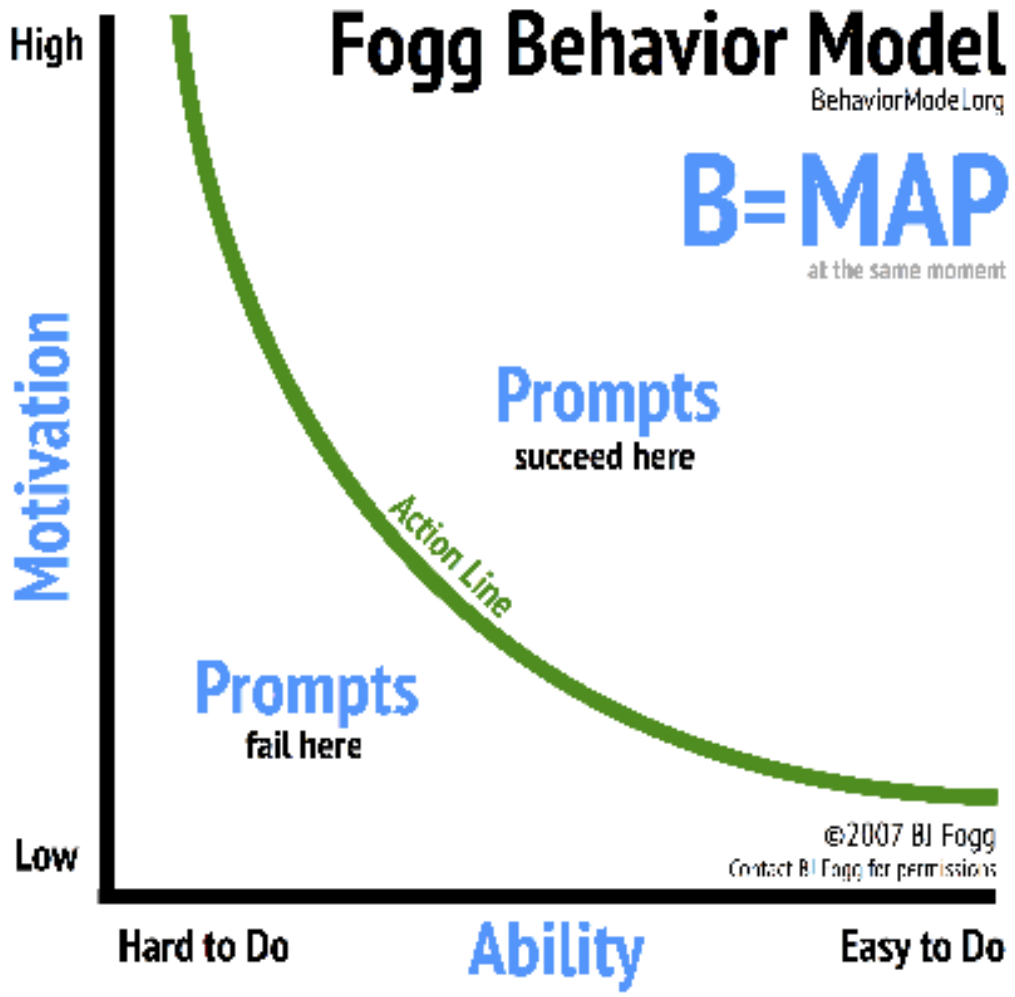
Universidad Veracruzana

- Momentos desencadenantes (**Prompts**)
  - Disparadores, señales, recordatorios

- Lograr un **cambio de comportamiento** requiere:
  - suficiente **motivación** de la persona para comprender la **formación** impartida
  - la capacidad para aplicar **habilidades** aprendidas.
  - Un **disparador** o señal que incite a actuar de inmediato

- **Ejemplos de disparadores**
  - Fondo de pantalla que diga **“¿Y si si hay alguien mirandote?”** (incrementa la motivación)
  - Notificación en el celular que pide presionar un botón que dice “**Si soy yo**”, durante una autenticación de dos pasos (facilita la acción)

- **Otros disparadores**
  - Notificación sobre cierre de tráfico justo antes de terminar la jornada laboral (**ataque: emocionales y contextuales**)



Dr. BJ Fogg founded the Behavior Design Lab at Stanford University,

Algunas estrategias para la concienciación en seguridad

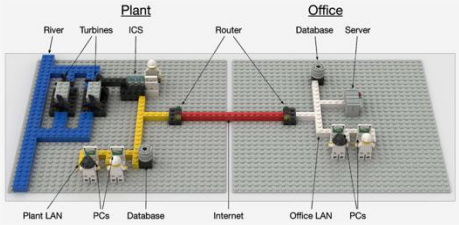
Universidad Veracruzana

- Simulaciones antiphishing
  - Medición del impacto
  - Momento de aprendizaje para el personal
  - Puede reducir la confianza del personal en la organización (auto ataque)
  - Puede reducir la atención a correos electrónicos importantes

- Capture the flag (para el personal de ciberseguridad)
  - Consciencia sobre vulnerabilidades y la forma de explotarlas

- Juegos de mesa (especialistas en TIC, desarrolladores, grupos de trabajo)
  - Ejemplos:
    - Ctr-Alt-Hack (juego de cartas)
    - dox3d!
    - Elevation of Privilege (EoP) de Microsoft (juego de cartas)
    - Decisions and Disruptions (juego de rol)
  - Deben formar parte de un programa planificado de transformación del comportamiento.

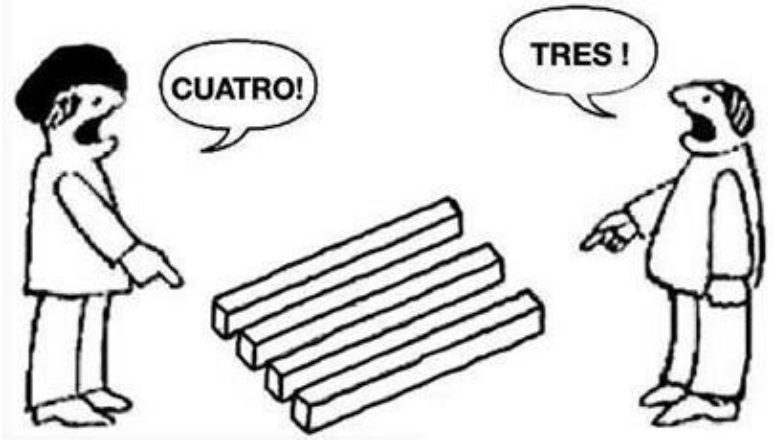




Modelos mentales de ciber riesgo y defensa

Universidad Veracruzana

- Conocimiento del espacio de trabajo a largo plazo
- Pueden variar en detalle. Ejemplos:
  - **Modelos de tarea y acción.** Permiten a los no expertos, por ejemplo, la manipulación de un dispositivo, auto, etc.
  - **Modelos estructurales.** Como planos que permite diagnosticar averías y repararlas.



- **Modelo mental**:
  - "*Se refieren a nuestros modelos conceptuales acerca de cómo funcionan los objetos, cómo tienen lugar los hechos o cómo se comporta la gente, y son resultado de nuestra* ***necesidad de formar explicaciones de las cosas***." (Fundación para la Universidad Oberta de Cataluña , s.f.).

- **Las personas No expertas en seguridad tienen un modelo mental distinto.**

- **Modelos mentales inadecuados** de seguridad, hacen a los **usuarios vulnerables** frente a adversarios inteligentes:
  - "Estos usuarios creen que su comportamiento actual no los hace realmente vulnerables, por lo que no necesitan hacer ningún esfuerzo adicional"

Actividad

Universidad Veracruzana

- Con base en el artículo: “**Bridging the Gap in Computer Security Warnings: A Mental Model Approach**”, disponible en https://ieeexplore-ieee-org.ezproxy.uv.mx/document/5669245, responde lo siguiente:
  - ¿Cómo influyen los modelos mentales en la atención a las advertencias de seguridad informática?
  - ¿Cuáles son las recomendaciones para aumentar la efectividad de los mensajes de advertencia, con usuarios no especializados en ciberseguridad?

Modelos mentales de Privacidad y Seguridad

- Diferentes maneras de comunicar riesgos

- Simplificar demasiado o dar solo datos técnicos no funciona bien para que la gente tome mejores decisiones.

- Diferentes enfoques de comunicación de riesgos:
  - Simplificar o exagerar el riesgo para cambiar el comportamiento
  - ofrecer información detallada que requiere respuestas racionales

- Ninguno ha sido completamente efectivo

Modelos mentales de Privacidad y Seguridad

- Las personas usan heurísticos o atajos mentales para evaluar riesgos que lleven a conductas de seguridad inadecuadas, como:
  - Basarse en información previa irrelevante.
  - Dificultad para imaginar consecuencias complejas.

- Propuesta: Utilizar "modelos mentales" — metáforas o esquemas cognitivos simples - para mejorar la comprensión y la toma de decisiones sobre seguridad.

Modelo de seguridad física

- Se basa en conceptos conocidos como puertas, cerraduras y perímetros físicos.
- Los ataques requieren presencia física, y las protecciones se entienden como barreras tangibles que pueden proteger activos.
- Puede motivar acciones como el uso de contraseñas fuertes o bloqueo de dispositivos.
- Limitaciones. No cubre la naturaleza dinámica y distribuida de las amenazas digitales.
    - Por ejemplo, un cable Ethernet puede atravesar paredes seguras, y la información digital puede ser copiada sin tener acceso físico.
    - El control físico es local y requiere inversión individual y comunitaria (como vigilancia vecinal).



Modelo médico

- Considera los ataques informáticos como enfermedades infecciosas que se propagan en la red.
- Ejemplo: el gusano Blaster y el "gusano bueno" worm_blastMS, que se propagaba para aplicar parches y curar sistemas infectados.
  - Destaca la importancia de la "higiene digital": cada usuario debe mantener su sistema protegido para evitar ser fuente de infección.
  - Implica responsabilidad individual y colectiva: la salud pública requiere coordinación, pero cada persona manteniendo ciertas prácticas reduce el riesgo de la comunidad.
  - Este modelo enfatiza que todos están en riesgo, y las medidas de seguridad son como cuidados médicos preventivos.
  - Se debe respetar la autonomía individual (por ejemplo, la opción de rechazar "tratamiento"), aunque esto puede implicar riesgos para la comunidad.



Modelo de guerra

- Considera la seguridad informática como un conflicto bélico con un enemigo persistente.
- Necesidad de defender perímetros robustos, vigilancia continua, inteligencia y preparación constante.
- La seguridad no consiste solo en evitar ataques, sino en responder activamente con múltiples capas de defensa.
- Este modelo puede incitar miedo o terror, similar al horror de la guerra, para motivar a los usuarios a protegerse.
- **Limitaciones**:
  - Tiende a eliminar la responsabilidad individual, convenciendo a los usuarios de que los expertos deben encargarse completamente de la seguridad.
  - Contrasta con la naturaleza abierta y distribuida de internet y la seguridad en red, que requiere flujo libre de información, a diferencia del control centralizado típicamente asociado a la seguridad nacional.



Modelo Económico o de Mercado

- Enfoca la seguridad como un problema de costos y beneficios, terceros implicados y contratos.
- **Idea**: la falta de seguridad provoca costos a terceros, por ejemplo, cuando un equipo vulnerable se usa para ataques a otros
- El costo de las vulnerabilidades debe traducirse a precios reales para que las unidades de negocio o usuarios inviertan adecuadamente en seguridad.
- Utiliza incentivos económicos para motivar comportamientos seguros o castigos por negligencia.
- **Limitaciones**:
  - Posibilidad de inducir excesiva atención a vulnerabilidades.
  - Desatención a otros riesgos.
  - Dificultad de asignar costos reales en entornos compartidos.



Conclusión sobre Modelos Mentales

Cada modelo mental tiene ventajas y limitaciones.

Una comunicación efectiva debería escoger y adaptar estos modelos para que los usuarios puedan actuar de manera más informada y responsable sin depender completamente de expertos.

El uso de modelos mentales en la comunicación del riesgo de seguridad informática puede hacer que los usuarios entiendan mejor los peligros y adopten comportamientos más efectivos, mejorando así la seguridad general del sistema

Universidad Veracruzana

Sesgos cognitivos

- Fenómeno estudiado tanto en psicología como en medicina, que hace referencia a la **tendencia sistemática de pensar de manera distorcionada** debido a la **interpretación sesgada de la información** disponible.

- **Desviación en la toma de decisiones racionales o del juicio objetivo**, que puede influir significativamente en las percepciones y actitudes de los individuos hacia diversos aspectos de la vida.

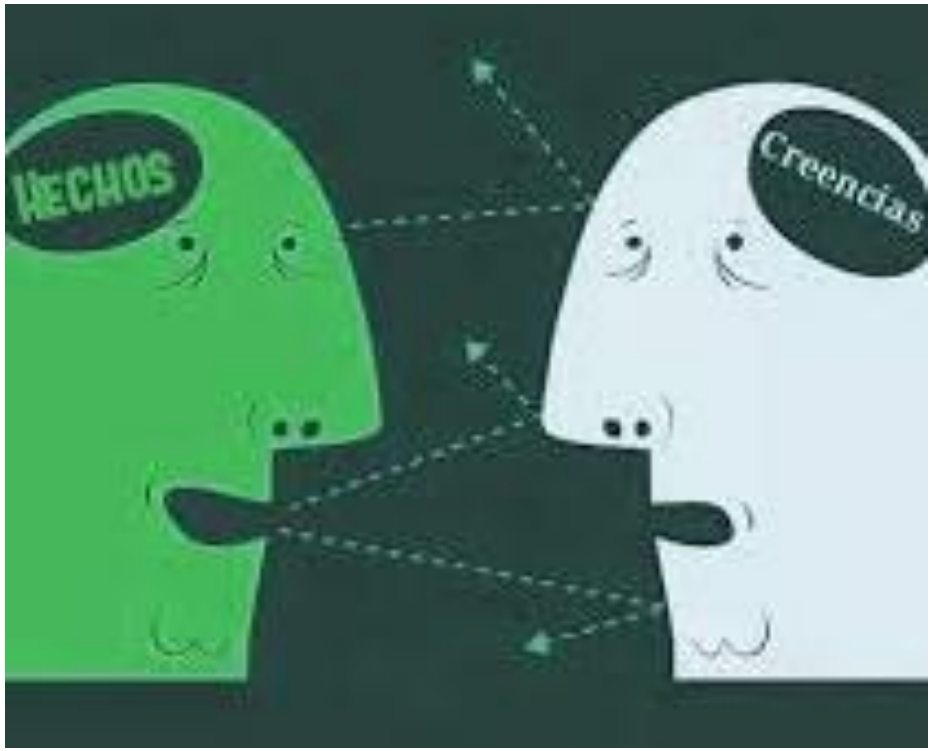
Clínica U. de Navarra (s.f.)

Sesgos Cognitivos

- También conocidos como **errores, predisposiciones cognitivas** o **ilusiones cognitivas**.

- **Procesamientos mentales imprecisos, distorsionados, o desinformados**, al intentar interpretar la realidad, realizar juicios, o simplemente aprehender el mundo.

- Comportamientos humanos **mayormente involuntarios** que suelen deberse a: **desinformación, cálculos apresurados, confusión durante la interpretación del contexto** en que se opera, desaciertos en el **uso de la lógica, o plena ignorancia**



García-Campos et. al. (2022)

Universidad Veracruzana

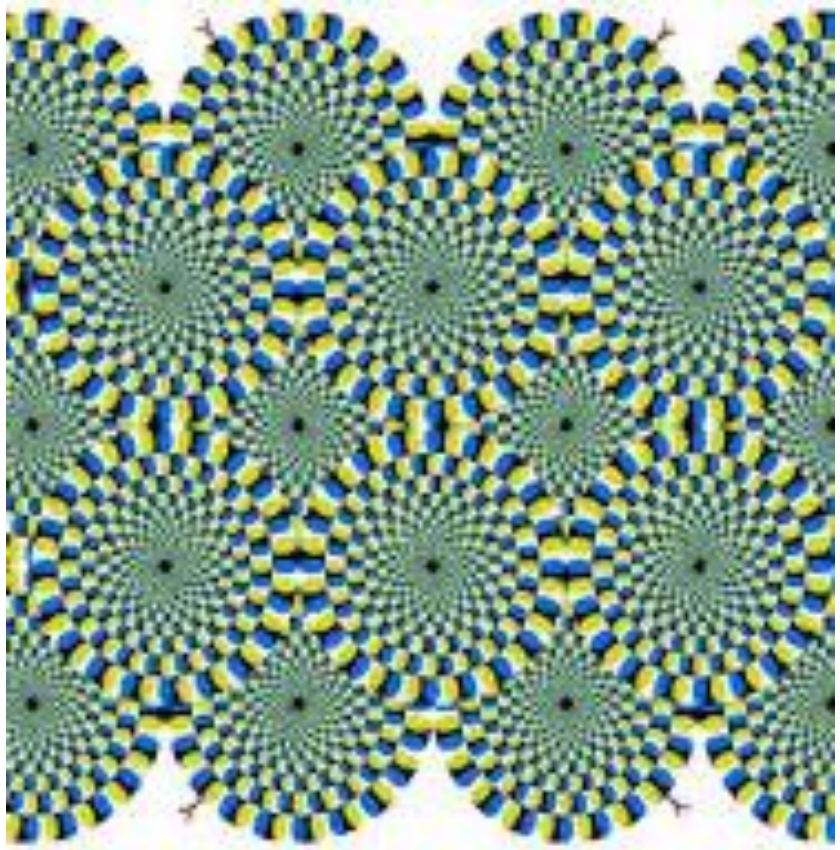
Características de las ilusiones cognitivas

a) Llevan a una **percepción**, juicio o memoria que **difiere de la realidad**

b) Se **desvían del estándar normativo de manera sistemática** y no solamente aleatoria

c) Son **involuntarias**

d) Son **difíciles de evitar**



Condicionan la manera en que percibimos nuestro entorno.

Algunas explicaciones del origen de los sesgos cognitivos (1)

Universidad Veracruzana

- Los seres humanos tenemos **limitantes en la cantidad de información que podemos procesar**. Para algunos autores, la clave del éxito está en la **inteligencia colectiva.**
  - “El conocimiento no se encuentra alojado en nuestra cabeza sino en las comunidades, los grupos, los equipos, etc”.

- Los sesgos existen porque **aprender lleva tiempo, corregir requiere esfuerzo.**



Algunas explicaciones del origen de los sesgos cognitivos (2)

Universidad Veracruzana

- **Representatividad**. Un sujeto juzga la probabilidad de que *A* pertenezca a *B* dependiendo de qué tan representativo es *A* de *B*
  - *Ejemplo: "Si una mujer estudió filosofía y estuvo interesada en problemas sociales, seguramente en la actualidad es feminista"*
- **Frecuencia**. Observada en ciertos comportamientos o resultados a lo largo de la historia.
  - *Ejemplo: "La terecera es la vencida"*
- **No se pueden reducir o eliminar los sesgos ofreciendo incentivos**, por **petición explícita** a que los sujetos presten mayor atención.
- Los sesgos **son sistemáticos y *no cambian con la educación*.**



Ejemplos de sesgos cognitivos en ciberseguridad

- Heurística afectiva.
  - Atajo mental influenciado por el estado emocional.
  - Una buena impresión de una situación, puede percibirla como de bajo riesgo y no investigar más a fondo.

- Anclaje
  - Las personas aceptan la primera información que se encuentran como la verdad absoluta al tomar decisiones.
  - Ejemplo: si un directivo de seguridad da prioridad a una amenaza cibernética en particular, los empleados de menor rango también lo hacen, sin evaluar el panorama general

Ejemplos de sesgos cognitivos en ciberseguridad

- Heurística de disponibilidad
  - Situaciones más frecuentes se recuerdan con mayor facilidad.
  - Ejemplo: cuando ante una amenaza o situación de seguridad, el equipo de seguridad toma decisiones con base en la memoria, experiencia o tendencias, en lugar de adoptar un enfoque metodológico que evalúe todos los riesgos.

- Racionalidad limitada
  - Cuando las personas intentan satisfacer en lugar de optimizar.
  - Ejemplo: cuando ante un ciberataque, los equipos de seguridad toman decisiones “suficientemente buenas”, con base en la información disponible y las herramientas a su disposición.

Ejemplos de sesgos cognitivos en ciberseguridad

- Sobrecarga de opciones
  - La sobrecarga de marketing de las soluciones de seguridad en el mercado, puede confundir a los equipos de seguridad, llevándolos a implementar soluciones incorrectas a un problema determinado.

- Fatiga por toma de decisiones
  - La toma de decisiones repetitiva consume recursos mentales, lo que puede provocar fatiga por toma de decisiones.
  - Ejemplo: cuando el personal de seguridad recibe tantas alertas diarias, que opta por ignorarlas cuando están sobrecargados de trabajo.

Ejemplos de sesgos cognitivos en ciberseguridad

- Comportamiento gregario
  - Los humanos imitan inconcientemente las acciones de un grupo más amplio.
  - Si un grupo de personas escribe contraseñas en notas adhesivas, este comportamiento podría propagarse al resto de la organización.

- Efecto de la autoconfianza
  - Cuando las personas permiten realizar acciones, positivas o negativas, en función de la recompensa emocional que obtengan por ellas.
  - Ejemplo: destruir documentos confidenciales y creen haber hecho una buena acción, pero posteriormente hacer click en un correo de phishing.

Ejemplos de sesgos cognitivos en ciberseguridad

- Sesgo de optimismo
  - Tener una falsa idea optimista de que gracias a la implementación de procesos y herramientas de seguridad, son inmunes a los ciberataques.
  - ”A mi no me va a pasar”.

- Agotamiento del ego
  - La fuerza de voluntad es limitada en los seres humanos y disminuye con el tiempo.
  - Ejemplo: seguir buenas prácticas de seguridad después de una sesión de capacitación, pero perder el hábito si no se realizan más capacitaciones y recordatorios periódicos.

Prácticas de seguridad recomendadas para audar a superar los prejuicios

- Priorizar la psicología sobre la tecnología.
  - Diseñar controles de ciberseguridad que consideren el comportamiento humano.
- Utilizar defensa en profundidad
  - Enfoque de seguridad por capas: combinación de controles técnicos, capacitación y procedimietnos
- Comunicación y formación periódicas.
  - Programas de concientización contínuos.

Actividad

- Considerando la lista de 50 sesgos cognitivos disponible en el siguiente enlace: https://ceciliacorespsicologa.es/50-sesgos-cognitivos/, elige 3 que consideres que pueden influir en las medidas de seguridad. Justifica tu respuesta.



Referencias

- Sasse, M.A. y Rashid, A.(2019). *Human Factors*. En Rashid, A. (Ed.). T*he Cyber Security Body of Knowledge v1.1*.0. University of Bristol.
- *UNIR. (s/f).Psicología del comportamiento: Qué es, objetivos y aplicaciones*. UNIR. Recuperado el 16 de agosto de 2024, de https://www.unir.net/salud/revista/psicologia-del-comportamiento/
- Lerner, R. M. , Bornstein, . Marc H. and Kagan, . Jerome (2024, July 12). *Human behaviour*. *Encyclopedia Britannica*. https://www.britannica.com/topic/human-behavior
- *Kaspersky*. (2017, septiembre 13). *What is Cybersecurity? Types, Threats and Cyber Safety Tips*. https://www.kaspersky.com/resource-center/definitions/what-is-cyber-security
- Arnal Sarasa, M.D. (2020). La conducta en sus contextos. https://trabajosocial.ucm.es/data/cont/docs/6-2016-04-05-LA%20CONDUCTA%20EN%20SUS%20CONTEXTOS.pdf
- Irel, A. (2023). What is Cyber Hygiene and Why is It Important? (s/f). Security. Recuperado el 30 de agosto de 2024, de https://www.techtarget.com/searchsecurity/definition/cyber-hygiene
- Fundación para la Universidad Oberta de Cataluña [OUC]. (s.f.). Design Toolkit | *Modelo mental*. Recuperado el 2 de septiembre de 2024, de https://design-toolkit.recursos.uoc.edu/es/modelo-mental/. CC-BY-SA
- Clínica U. Navarra. (s/f). *Qué es sesgo cognitivo*. Diccionario médico. https://www.cun.es. Recuperado el 6 de septiembre de 2024, de https://www.cun.es/diccionario-medico/terminos/sesgo-cognitivo
- García-Campos, J., Sarabia-López, S., & Hernández-Chávez, P. (2022). Tres grandes enigmas de los sesgos cognitivos. SCIO: Revista De Filosofía, (22), 99-125.
- *10 sesgos cognitivos que pueden hacer fracasar los programas de ciberseguridad | Revista de Seguridad*. (s/f). Recuperado el 11 de septiembre de 2025, de https://www.securitymagazine.com/articles/96918-10-cognitive-biases-that-can-derail-cybersecurity-programs
- Di Nocera, F., Tempestini, G., & Orsini, M. (2023). Usable Security: A Systematic Literature Review. Information, 14(12), 641. https://doi.org/10.3390/info14120641
- Camp, L. J. (2009) . "Mental models of privacy and security," in IEEE Technology and Society Magazine, vol. 28, no. 3, pp. 37-46. https://doi.org/10.1109/MTS.2009.934142